

Implementación de Roles y Permisos

Actividad N°: 19 **Fecha:** 25/06/2026 **Horario:** 14:00 a 20:00 **Tutor Empresarial:** Miguel Vivanco **Pasante:** Gabriel

1. Objetivo del día

Implementar y consolidar el control de acceso basado en roles (RBAC) en todos los endpoints del sistema, y corregir la inconsistencia de permisos detectada en la revisión de diseño de la Semana 3.

2. Mecanismo de autorización (middleware/auth.js)

```
const authorize = (...roles) => (req, res, next) => {
  if (!req.user) return res.status(401).json({ success: false, message: 'Usuario no autenticado' });
  const flatRoles = roles.flat();
  if (!flatRoles.includes(req.user.rol)) {
    return res.status(403).json({ success: false, message: 'No tiene permisos para realizar esta acción' });
  }
  next();
};
```

`authorize()` se usa siempre después de `auth`, de modo que `req.user` ya está disponible y verificado.

3. Matriz de permisos consolidada (estado actual del backend)

Endpoint	Método	Roles permitidos
/api/auth/login	POST	Público
/api/auth/change-password	POST	Cualquier autenticado
/api/auth/logout	POST	Cualquier autenticado
/api/auth/profile	GET	Cualquier autenticado
/api/users	GET, POST	jefe
/api/users/:id	PUT, DELETE	jefe
/api/tickets	GET	jefe, staff (filtrado por punto de trabajo si es staff)
/api/tickets/stats	GET	jefe
/api/tickets/transaction/:id	GET	jefe

Endpoint	Método	Roles permitidos
/api/tickets/:id/print	POST	jefe, staff
/api/tickets/:id/reprint	POST	jefe
/api/tickets/:id/canje	POST	jefe, staff
/api/tickets/bulk-canje	POST	jefe (corregido hoy — ver sección 4)
/api/puntos-venta	GET	Cualquier autenticado
/api/puntos-venta	POST	jefe
/api/puntos-venta/:id	PUT, DELETE	jefe
/api/puntos-venta/staff/tickets	GET	staff, impresor
/api/audit, /api/audit/summary	GET	jefe

4. Corrección aplicada: permisos de canje masivo (**bulk-canje**)

Como quedó registrado como pendiente en el **Acta de Revisión del Diseño General (Semana 3, día 15)**, se detectó que el backend autorizaba tanto a **jefe** como a **staff** en la operación de canje masivo, mientras que el diseño de interfaz y la regla de negocio acordada con el tutor empresarial reservan esa operación exclusivamente al rol Jefe (por ser una operación de supervisión sobre grandes lotes de boletos).

Archivo modificado: `backend/src/routes/tickets.js`

```
- router.post('/bulk-canje', auth, authorize('jefe', 'staff'),
  auditLogger('canje_masivo'), bulkCanjeTickets);
+ // Solo Jefe: el canje masivo es una operación de supervisión (ver acta de
  revisión de diseño, Semana 3)
+ router.post('/bulk-canje', auth, authorize('jefe'), auditLogger('canje_masivo'),
  bulkCanjeTickets);
```

Con este cambio, el backend queda alineado con el frontend (que ya solo muestra la funcionalidad de canje masivo al rol Jefe), cerrando la brecha de seguridad detectada: un usuario Staff que intentara invocar el endpoint directamente (sin usar la interfaz) ahora recibe **403 Forbidden**.

5. Verificación de la corrección

Escenario	Antes	Después
Jefe llama a POST /api/tickets/bulk-canje	200 OK	200 OK (sin cambios)
Staff llama a POST /api/tickets/bulk-canje directamente (ej. con Postman)	200 OK ⚠️ (no debía permitirlo)	403 Forbidden ✅

6. Conclusiones del día

Se consolidó la matriz de permisos de todo el backend y se corrigió la inconsistencia detectada en la Semana 3, dejando el control de acceso alineado entre frontend y backend para la operación de canje masivo.

Observaciones: Corrección de permisos aplicada y verificada; sin observaciones adicionales.